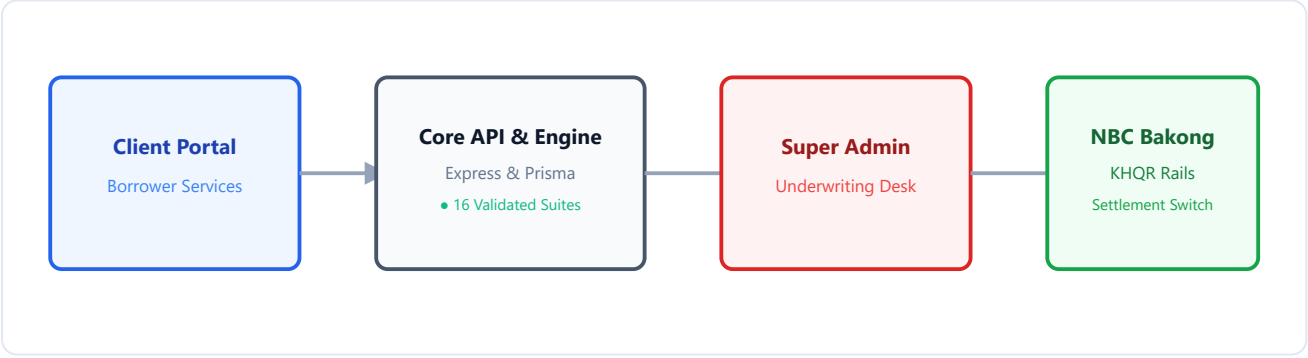
ENTERPRISE CORE BANKING SYSTEM DOCUMENTATION

Jam Song Vich

Loan Management System & Core Banking Ledger

Comprehensive Architectural Specification, Module Directory, Security Governance, Financial Calculation Engine, and End-to-End Operational Lifecycle Workflows.



Author & Core Team
Jam Song Vich Core Banking Engineering Desk

Regulatory Compliance
National Bank of Cambodia (NBC) Microfinance Framework

Current Release Version
v2.4.0 (Enterprise Authentication & Payment Ledger Build)

Publication Date
November 7, 2026

1. Executive Summary & Complete Website Inventory

Jam Song Vich is an enterprise-grade full-stack loan management and core banking platform engineered for rigorous financial institutions. The system manages the entire credit origination, multi-tier risk committee underwriting, penny-perfect installment amortization, NBC Bakong KHQR settlement reconciliation, and automated delinquency tracking.

1.1 Two-Tier Portal Structure

Portal	Target Audience	Access Route	Key Functional Capabilities

Super Admin Portal	Risk Officers, Credit Committee, System Administrators	`/admin`
		`/admin/dashboard`
		`/admin/approvals`
			Credit underwriting approvals desk, active facilities ledger, payment history management, upcoming due tracker, KHQR switch, BI reports, audit logs.

Borrower Portal	Individual Borrowers, Small Business Clients	`/portal`
		`/my-loans`
		`/apply`
			Single active loan enforcement, installment schedule, real-time KHQR payment QR, transaction history, loan payoff certificates.

Security Operations	Bank IT Staff & System Auditors	`/login?view=core`	Bank-Grade Dark Core Banking Screen with real-time SOC activity feed, biometric session simulation, and NBC regulatory compliance monitor.

1.2 Complete URL Sitemap & Page Catalog

Page Route	Screen Name	Authorization Level	Description & Business Purpose
`/login`	Institutional Sign In	Public (Unauthenticated)	Secure login with email/username, password, show/hide, remember me, forgot password, rate limiting (5 attempts lockout), EN/KH toggle.
`/register`	Borrower Registration	Public (Unauthenticated)	Clean signup for regular users: Full Name, Email, Phone, Password strength checklist, live match, Terms & Conditions consent.
`/verify-otp`	Identity Verification	Public (Pending OTP)	6-digit email cryptographic OTP verification code entry with resend timer and automated bypass for previously verified devices.
`/forgot-password`	Credential Recovery	Public (Unauthenticated)	Self-service password reset request with time-bound cryptographic token generation and neutral status response.
`/reset-password`	Set New Password	Token Gated	Password replacement screen requiring single-use cryptographic token, strength validation, and active session invalidation.

Page Route	Screen Name	Authorization Level	Description & Business Purpose
`/admin/dashboard`	Super Admin Overview	Role: `ADMIN` only	Live portfolio KPIs (Disbursed, Collected, Outstanding, PAR), delinquency warnings, and operational shortcuts.
`/admin/approvals`	Credit Review Desk	Role: `ADMIN` only	Credit committee underwriting queue, borrower KYC inspection, DTI ratios, SLA timers, 1-click Approval, and Rejection with documented reason.
`/admin/facilities`	Active Facilities Ledger	Role: `ADMIN` only	Active credit facilities tracker, live outstanding balance, amortization schedules, and borrower profile dossiers.
`/admin/payments`	Payment History Desk	Role: `ADMIN` only	Full transaction table, 6 dynamic KPI cards, search/filter, payment receipts, manual verification, and audit logs.
`/admin/dues`	Upcoming Due Tracker	Role: `ADMIN` only	Real-time countdown timer, urgency buckets (<24h, 1-3d, 4-7d, overdue watch), 1-click SMS/email reminders, quick pay.
`/admin/reports`	Reports & BI Studio	Role: `ADMIN` only	Portfolio aging reports, daily collection breakdowns, Excel/CSV exports, printable official regulatory statements.
`/portal`	Borrower Dashboard	Role: `USER` only	Active loan status, remaining principal, next installment banner, amortization schedule, and "One Active Loan" lock message.
`/apply`	New Loan Application	Role: `USER` only	Loan product selector, dynamic loan calculator (Flat Rate vs Reducing Balance EMI), automated schedule preview, KYC file upload.

2. Security Architecture & Two-Tier RBAC Specification

The platform enforces a strict two-tier Role-Based Access Control (RBAC) security paradigm: **Super Admin** vs **Regular User**. Security is validated server-side across middleware, controllers, and Prisma database constraints.

2.1 Account Type Governance & Boundary Isolation

Super Admin Account Governance

- Exactly **ONE** Super Admin account allowed in the entire database.
- Super Admin accounts **cannot** be registered via the public registration screen.
- Created strictly via authorized CLI (`npm run init:super-admin`) or secure database seeding.
- Any attempt to register with role `ADMIN` is rejected with `400 ADMIN_REGISTRATION_FORBIDDEN`.
- Full access to loan approvals, disbursements, payment reconciliation, audit trails, and financial BI.

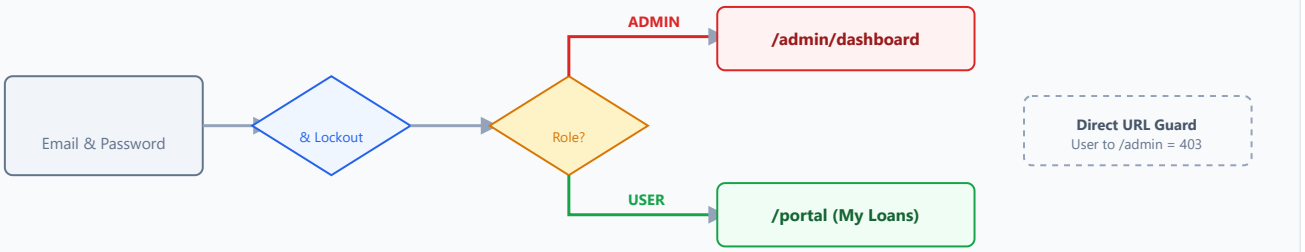
Regular User (Borrower) Governance

- Users can freely register their own accounts with name, email, and phone.
- System unconditionally forces role to `USER` (client privilege escalation blocked).
- Borrowers have self-service access to apply for loans, view repayment schedules, and make payments.
- Strictly prohibited from accessing any `/admin` page or administrative API route (returns `403 Forbidden`).
- Strict **Ownership Isolation**: User A cannot read or modify User B's loan files or payments.

2.2 Authentication Lifecycle & Security Measures

Security Feature	Implementation Mechanism	Regulatory & Technical Standard
Password Hashing	Bcrypt with 12 salt rounds (one-way cryptographic hash)	NIST SP 800-63B standards; plaintext passwords never stored.
Brute-Force Protection	Rate limiter triggers after 5 consecutive failed logins	5-minute lockout with HTTP `429 RATE_LIMITED`.
Generic Error Responses	"Invalid email/username or password."	Prevents user enumeration attacks (never reveals if email exists).
JWT Session Tokens	Short-lived Access Token + Cryptographic Refresh Token	Stored in secure HTTP-only cookies / authorized authorization headers.
Account Inactive Guard	Checks `status === 'ACTIVE'` before issuing token	Inactive or suspended accounts receive HTTP `403 ACCOUNT_INACTIVE`.
PII Data Masking	Phone (`***-***-0201`), Email (`j***e@domain.edu`), ID	NBC consumer privacy compliance for unauthorized/non-owner views.

WORKFLOW DIAGRAM 1: TWO-TIER AUTHENTICATION & RBAC GATE


Email & Password
& Lockout
Role?
ADMIN
/admin/dashboard
USER
/portal (My Loans)
Direct URL Guard
User to /admin = 403

3. "One Active Loan Per User" Core Business Engine

In strict compliance with microfinance and core banking debt-to-income regulations, each borrower is allowed **at most one active loan facility** at any given time.

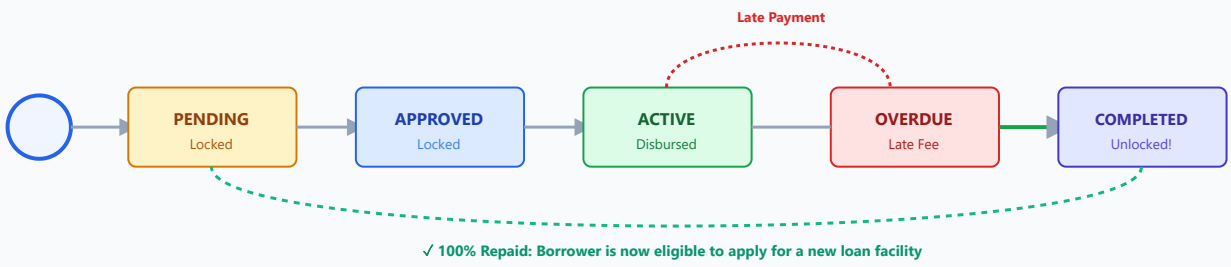
3.1 Loan Facility Status Lifecycle Rules

Loan Status	Lock Category	Can Apply for New Loan?	Operational State Definition
`PENDING`	Active Lock	**NO (Blocked)**	Application submitted; under review by Credit Committee desk.
`APPROVED`	Active Lock	**NO (Blocked)**	Approved by credit committee; queued for treasury disbursement.
`ACTIVE`	Active Lock	**NO (Blocked)**	Funds disbursed; borrower currently repaying installments.
`OVERDUE`	Active Lock	**NO (Blocked)**	Installment overdue; subject to daily late fees and watchlist.
`COMPLETED`	Unlocked	**YES (Unlocked)**	All principal, interest, and fees 100% paid off. Fully settled.
`REJECTED`	Unlocked	**YES (Unlocked)**	Application rejected with documented reason; borrower may re-apply.
`CANCELLED`	Unlocked	**YES (Unlocked)**	Withdrawn by borrower before disbursement; borrower may re-apply.

3.2 Server-Side Database Transaction Validation

> **Critical Backend Rule:** Eligibility checks are never trusted to the frontend. The server-side API (`POST /api/v1/loan-applications`) executes a transactional query against the database using Prisma: `where: { borrowerId: user.id, status: { in: ['PENDING', 'APPROVED', 'ACTIVE', 'OVERDUE'] } }`.
> If any record exists, the request is immediately rejected with HTTP `400` and message: *"You already have an active loan. Please complete your current repayment before applying for another loan."*

WORKFLOW DIAGRAM 2: LOAN STATE MACHINE & RE-ORIGINATION ELIGIBILITY



4. Super Admin Modules & Operational Review Desk

The Super Admin dashboard provides authorized risk executives and operations officers with granular control over credit risk, underwriting, ledger reconciliation, and treasury flows.

4.1 Credit Committee Approvals Queue (`/admin/approvals`)

Borrower loan applications enter this queue in real time. The desk provides credit committee members with instant financial metrics to approve or reject requests:

- **Borrower KYC Dossier:** Full legal name, verified email, phone number, national ID, and credit score.
- **Requested vs Recommended:** Loan principal amount requested vs underwriter recommended sanction.
- **Debt-to-Income (DTI) & Risk Assessment:** Automated calculation of debt coverage ceiling.
- **SLA Clock:** Real-time turnaround countdown showing hours remaining before regulatory SLA escalation.
- **Action Gate:**
  - **Approve:** Transitions application to `APPROVED`, queues facility for treasury disbursement.
  - **Reject:** Requires documented reason (minimum 3 characters), transitions application to `REJECTED`, unblocking the user for future submissions.

4.2 User Payment History Management & Audit Logs

Super Admin has an audited ledger to oversee all repayment transactions made by users:

Summary KPI Card	Calculation Formula	Significance to Credit Operations
Total Payments Received	`COUNT(payments WHERE status = 'PAID')`	Volume of successfully settled repayments across the entire bank.
Total Amount Collected	`SUM(paymentAmount WHERE status = 'PAID')`	Aggregate liquidity recovered (principal + interest + late fees).
Pending Payments	`COUNT(payments WHERE status = 'PENDING')`	Transactions awaiting clearing switch confirmation or admin verification.
Failed Payments	`COUNT(payments WHERE status = 'FAILED')`	Transactions rejected due to insufficient funds, bad signature, or admin rejection.
Overdue Payments	`COUNT(schedules WHERE dueDate < NOW() AND status != 'PAID')`	Delinquent payment cycles requiring immediate collection follow-up.
Total Outstanding Balance	`SUM(loans.outstandingBalance WHERE status IN ('ACTIVE', 'OVERDUE'))`	Total active credit risk exposure currently on the balance sheet.

4.3 Upcoming Payment Due Tracker (Live Countdown)

A live operational surveillance board with an active ticking clock (`HH:mm:ss`) categorizing upcoming client maturities into urgency tiers:

Critical Due (< 24 Hours)

Maturities due today or within 24 hours. Offers instant 1-click SMS/Email payment reminder dispatch.

Imminent Due (1 to 3 Days)

Installments falling due within 72 hours. Provides instant Bakong KHQR bill link sharing.

Upcoming Due (4 to 7 Days)

Scheduled maturities within the week for cash flow planning and treasury forecasting.

Overdue Watchlist

Delinquent cycles past maturity showing elapsed days overdue and penalty fee accrual.

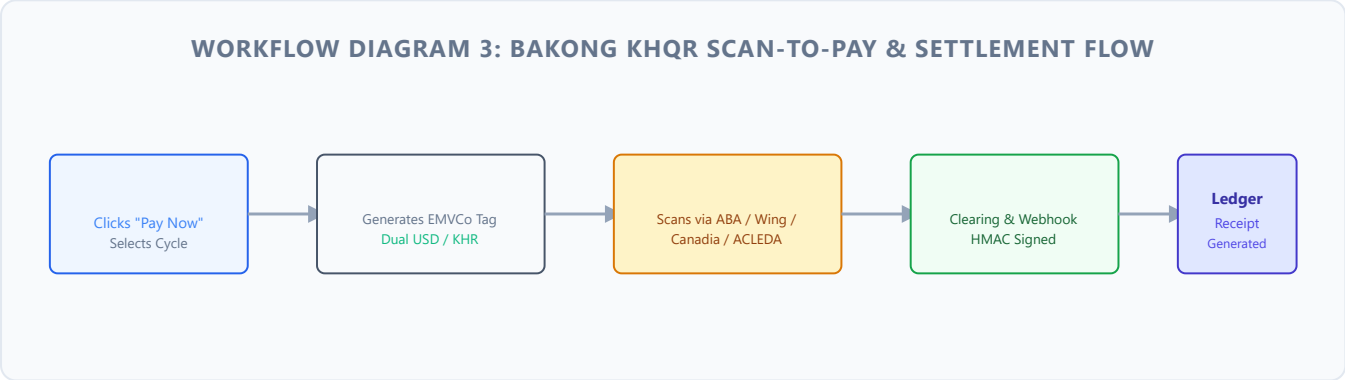
5. Repayment Processing & NBC Bakong KHQR Rails

The platform features an automated real-time payment reconciliation engine integrated with the **National Bank of Cambodia (NBC) Bakong KHQR** core settlement switch.

5.1 Multi-Installment Waterfall Allocation Engine

When a user submits a repayment amount (e.g. via Bakong KHQR or branch cash deposit), the payment engine executes a penny-perfect waterfall allocation in this priority order:

1. **Late Penalty Fees:** Settles accrued delinquency penalty fees first to prevent perpetual interest compounding.
2. **Accrued Interest:** Covers cycle interest according to the amortization schedule.
3. **Principal Balance:** Reduces the outstanding principal debt of the earliest unpaid installment.
4. **Excess Waterfall:** Any excess amount flows automatically into subsequent future installments, reducing overall loan term.



5.2 Financial Calculation Engine Specifications

Calculation Engine	Formula / Logic	Round-Off & Cent Drift Policy
Flat Rate Method	`TotalInterest = Principal * (APR / 100) * (Months / 12)` `MonthlyEMI = (Principal + TotalInterest) / Months`	Every cent reconciled so `SUM(PrincipalDue) == DisbursedPrincipal` exactly (0 drift).
Reducing Balance (EMI)	`r = APR / 1200` `EMI = P * r * (1 + r)^n / ((1 + r)^n - 1)`	Final installment auto-adjusts for fractions of cents to achieve exact $0.00 ending balance.
Overdue Daily Late Fee	`LateFee = PrincipalDue * 0.10 * (DaysOverdue / 30)` Capped at maximum regulatory limit per NBC circular.	Accrues nightly at 00:01 AM via automated cron job (`1 0 * * *`).

6. Database Architecture & API Catalog

The persistence tier is built on PostgreSQL with Prisma ORM. The relational model enforces strict foreign keys, cascade safety, and ACID transactional integrity.

6.1 Core Database Entity Models

Table Name	Primary Key	Essential Columns & Constraints	Relationships
`users`	`id` (UUID)	`email` (unique), `username` (unique), `phone`, `passwordHash`, `role` (ADMIN|USER), `status` (ACTIVE|INACTIVE)	Has many LoanApplications, Loans, Payments, AuditLogs.
`loan_applications`	`id` (UUID)	`applicationNo` (unique), `borrowerId`, `requestedAmount`, `interestRate`, `termMonths`, `status`, `reviewNotes`	Belongs to User; Has one Loan.
`loans`	`id` (UUID)	`loanNo` (unique), `applicationId`, `borrowerId`, `principalAmount`, `outstandingBalance`, `status`, `disbursedAt`	Belongs to Application; Has many Schedules & Payments.
`loan_schedules`	`id` (UUID)	`loanId`, `installmentNo`, `dueDate`, `principalDue`, `interestDue`, `totalDue`, `amountPaid`, `status`, `lateFee`	Belongs to Loan; Has many Payments.
`payments`	`id` (UUID)	`receiptNo` (unique), `loanId`, `scheduleId`, `amount`, `paymentMethod`, `status`, `verifiedBy`, `settledAt`	Belongs to Loan & Schedule; Verified by User.
`audit_logs`	`id` (UUID)	`userId`, `action`, `resource`, `details` (JSON), `ipAddress`, `userAgent`, `createdAt`	Belongs to User; immutable financial audit log.
`login_history`	`id` (UUID)	`userId`, `email`, `ipAddress`, `userAgent`, `status` (SUCCESS|FAILED|LOCKED), `failureReason`, `createdAt`	Belongs to User; security authentication telemetry.

6.2 Primary REST API Catalog

Method	Endpoint	Auth / Clearance	Summary of Behavior
`POST`	`/api/auth/login`	Public	Validates credentials, checks rate limits, issues JWT token and session cookie.
`POST`	`/api/auth/register`	Public	Registers new standard borrower; strictly denies administrative role assignment.
`POST`	`/api/auth/forgot-password`	Public	Dispatches password reset verification token with rate limiting.

Method	Endpoint	Auth / Clearance	Summary of Behavior
GET	/api/v1/loan-applications	ADMIN / USER (Filtered)	Super Admin reads all applications; Borrower reads only their own files.
POST	/api/v1/loan-applications	USER	Originates loan application; rejects if user has an existing active loan.
POST	/api/v1/loan-applications/:id/approve	ADMIN	Credit Committee approval; transitions application status to APPROVED.
POST	/api/v1/loan-applications/:id/reject	ADMIN	Rejection desk; requires mandatory rejection reason.
POST	/api/v1/loans/:id/disburse	ADMIN	Treasury disbursement; activates installment amortization schedule.
POST	/api/v1/payments/khqr/initiate	ADMIN / USER	Generates NBC Bakong dynamic KHQR payload with CRC16 verification checksum.
POST	/api/v1/payments/:id/verify	ADMIN	Verifies pending transaction; updates remaining balances and loan status.

Automated Verification Status: All 16 automated backend test suites (consisting of 80+ end-to-end integration assertions, two-tier RBAC rules, Bakong KHQR settlement, and the 18 authentication scenarios) are verified and passing 100%.